



THREAT ADVISORY

Two Vulnerabilities discovered in AWS Client VPN

TA2022096

Threat Level

AMBER

Publish Date – April 19, 2022

Two flaws have been discovered in the AWS VPN Client. One of them (CVE-2022-25166) was discovered due to a time-of-check to time-of-use (TOCTOU) condition, which could lead to privilege escalation. Another vulnerability (CVE-2022-25165) could allow an attacker to obtain an end-Net-NTLMv2 user's hash if a specially crafted configuration file is used, including a specific network file path imported into the client, and the machine's firewall is configured to allow outbound external connections.

These vulnerabilities have been fixed in version 3.0.0.

Potential MITRE ATT&CK TTPs are:

TA0042: Resource Development

TA0004: Privilege Escalation

TA0006: Credential Access

T1588: Obtain Capabilities

T1588.006: Obtain Capabilities: Vulnerabilities

T1548: Abuse Elevation Control Mechanism

T1068: Exploitation for Privilege Escalation

T1555: Credentials from Password Stores

T1555.004: Credentials from Password Stores: Windows Credential Manager

Vulnerability Details

CVE ID	Affected Products	Affected CPE	Vulnerability Name	CWE ID
CVE-2022-25165	AWS Client VPN version 2.0.0	cpe:2.3:a:amazon: aws_vpn_client:2. 0.*.*.*.*.*.*	Information Disclosure via UNC Path	CWE-200
CVE-2022-25166			Arbitrary File Write as SYSTEM	CWE-367

Patch Links

<https://aws.amazon.com/vpn/client-vpn-download/>

References

<https://rhinosecuritylabs.com/aws/cve-2022-25165-aws-vpn-client/>